

GOVERNANCE · CMMC DOCUMENTATION

How Many Documents Does CMMC Level 2 Actually Require?

NIST 800-171 names 110 requirements but no document count. Scoping a CMMC Level 2 documentation set is a governance decision - here is what the 110 imply.

BY MAXINE READING TIME · 6 MIN CMMC · NIST-800-171 · COMPLIANCE · GOVERNANCE · DOCUMENTATION

Ask five vendors how many documents CMMC Level 2 requires and you will get five confident numbers, every one of them wrong in the same way: NIST SP 800-171 does not name one. The framework states 110 security requirements, assessed through 320 objectives, and nowhere does it prescribe a count of policies, plans, or procedures. The size and shape of your documentation set is a decision you make - a governance decision about scope - and the assessor does not merely read the documents. The assessor assesses the decision.

That silence in the regulation produces two failure modes, and the better-funded one is worse. The first is the stationery response: buy the biggest binder on the market, two hundred templates deep, and mistake weight for readiness. It feels like safety and it is actually a liability register. Every controlled document you publish is a commitment that your organization does the thing the document says, and an assessor's method is to sample practice against paper. A procedure nobody follows is not neutral shelf-filler; it is a finding you wrote yourself, in advance, in your own voice. The arithmetic compounds quietly: every document needs an owner, an approver, and a review cadence, and two hundred documents on an annual cycle is a review due roughly every working day of the year. A thirty-person machine shop did not budget for that hidden employee, so the reviews lapse, and now the set is both oversized and stale.

The opposite failure forfeits points rather than accruing them. "We have policies" is the sentence assessors hear most and credit least, because a policy answers only the top layer of what the 320 objectives ask. The objectives want to know whether things are *defined*, *specified*, *identified*, and then whether the defined thing actually operates - and those answers live in procedures, plans, agreements, and above all in the records that a working procedure throws off. A policy stating that access is restricted to authorized users cannot produce the user access register that shows who was authorized in March and who signed for it. Intent without machinery scores as absence.

Every controlled document you publish is a promise an assessor will check you kept.

Read the 110 as a bill of materials, not a reading list

The way out of both failures is to derive the set from the requirements instead of buying it by the pound, and MacTech's own program is a usable worked example. The canonical set MacTech maintains for its CUI enclave runs to 64 controlled documents, mapped to all 110 requirements and all 320 assessment objectives. The anatomy is the instructive part: 18 policies, 29 procedures, 6 system-scope descriptions, 4 plans (incident response and security assessment among them), 4 signed agreements, 2 technical standards, and one system security plan.

Notice what dominates. Procedures outnumber policies twenty-nine to eighteen, because that is roughly the ratio the requirements themselves imply: for every "we shall" the framework wants at least one "here is how, step by step, and here is the record it leaves." The smaller families earn their places the same way. System descriptions are scoping documents - boundary, data flows, what is inside and what is out - and they exist because an assessor's first hour is

FIELD COPY
ISSUE N° 021
CMMC

64
CONTROLLED DOCUMENTS IN
MACTECH'S CANONICAL SET,
COVERING ALL 110
REQUIREMENTS

29 : 18
PROCEDURES TO POLICIES -
THE SET'S CENTER OF
GRAVITY IS THE HOW, NOT
THE SHALL

1,595
OF 1,595 INTAKE ANSWERS
LANDED EXACTLY WHERE
THE TRACE SAID THEY
WOULD

◆ THE DOCUMENTS A
FORM CANNOT WRITE
MacTech's intake workbook
deliberately excludes an expert-
led tier, the SSP first among
them. A system security plan
describes one specific system
as it actually runs; a version
derived from form answers
would be the generic SSP an
assessor learns to distrust by
page two.

